MARCO DE EVALUACIÓN DE CIBERSEGURIDAD

LLM-Sec

Evaluación de la postura de ciberseguridad en plataformas que integran LLM

Alineado a OWASP LLM Top 10:2025,
ISO/IEC 33001 e ISO/IEC 27002:2022

Valentina Paz Campos Olguín

Universidad de Santiago de Chile | DIINF

Versión 1.0 | Julio 2026

Control de versiones

Versión	Fecha	Autor	Descripción
1.0	Julio 2026	V. Campos Olguín	Versión inicial del documento del marco.

Índice general

Control de versiones 2

1. Introducción 1
- 1.1. Propósito del documento . . . 1
- 1.2. Alcance . . . 1
- 1.3. Audiencia . . . 1
- 1.4. Referencias normativas . . . 2
- 1.5. Convenciones del documento . . . 2

2. Modelo de madurez 3
- 2.1. Identificación de activos del sistema RAG . . . 3
- 2.2. Valoración de riesgo por activo . . . 5
  - 2.2.1. Escala de valoración . . . 5
  - 2.2.2. Matriz de riesgo . . . 5
  - 2.2.3. Interpretación y priorización . . . 5
  - 2.2.4. Trazabilidad hacia las subdimensiones . . . 6
- 2.3. Estructura del modelo . . . 7
- 2.4. Niveles de madurez . . . 7
- 2.5. Subdimensiones . . . 8
  - 2.5.1. D1: Protección de entrada . . . 8
  - 2.5.2. D2: Control de contexto RAG . . . 8
  - 2.5.3. D3: Gestión de salida . . . 8
  - 2.5.4. D4: Monitoreo y trazabilidad . . . 8
  - 2.5.5. D5: Gobernanza organizacional . . . 9
- 2.6. Regla de piso mínimo . . . 9

3. Taxonomía de controles 10
- 3.1. Estructura de los controles . . . 10
- 3.2. D1: Protección de entrada . . . 10
- 3.3. D2: Control de contexto RAG . . . 11
- 3.4. D3: Gestión de salida . . . 11
- 3.5. D4: Monitoreo y trazabilidad . . . 12
- 3.6. D5: Gobernanza organizacional . . . 12
- 3.7. Distribución de controles . . . 12

4. Perfiles organizacionales 13
- 4.1. P1: PYME . . . 13
  - 4.1.1. Trayectoria recomendada . . . 13

4.1.2. Controles prioritarios . . . 14
4.2. P2: Mediana/Grande . . . 14
4.2.1. Trayectoria recomendada . . . 14
4.2.2. Controles prioritarios . . . 14
4.3. P3: Crítica regulada . . . 14
4.3.1. Trayectoria recomendada . . . 14
4.3.2. Obligaciones regulatorias aplicables . . . 15
4.3.3. Controles prioritarios . . . 15

5. Guía de evaluación **16**
5.1. Flujo de evaluación . . . 16
5.2. Nivel verificado y nivel declarado . . . 16
5.3. Criterios de verificación por fuente de evidencia . . . 17
5.3.1. Configuración . . . 17
5.3.2. Experimental . . . 17
5.3.3. Declarativo . . . 17
5.4. Matriz RACI . . . 17
5.5. Ciclo de mejora . . . 17

A. Resumen de controles por nivel **18**

B. Mapeo normativo **19**

Capítulo 1

Introducción

1.1 Propósito del documento

Este documento especifica el marco LLM-Sec, un instrumento de evaluación de la postura de ciberseguridad para plataformas que integran modelos de lenguaje de gran escala (LLM) en arquitecturas de generación aumentada por recuperación (RAG). El marco combina un modelo de madurez de seis niveles con una taxonomía de 62 controles operacionales, proporcionando al evaluador criterios cuantificables y reproducibles para determinar el estado de seguridad de un sistema RAG.

El presente documento es un artefacto independiente de la tesis que lo valida experimentalmente. Su estructura permite su aplicación autónoma por parte de cualquier organización, sin requerir acceso al experimento de laboratorio descrito en la tesis.

1.2 Alcance

El marco LLM-Sec está diseñado para evaluar sistemas RAG que cumplan las siguientes condiciones:

- Utilizan un modelo de lenguaje como componente de inferencia.
- Incorporan una base de datos vectorial como fuente de contexto.
- Operan en un entorno donde la entrada del usuario se procesa en lenguaje natural.

El marco cubre cuatro categorías de amenaza del OWASP LLM Top 10:2025 pertinentes al flujo RAG: LLM01 (Prompt Injection), LLM02 (Sensitive Information Disclosure), LLM07 (System Prompt Leakage) y LLM08 (Vector and Embedding Weaknesses).

1.3 Audiencia

- **Evaluadores de seguridad:** profesionales que realizan auditorías de sistemas RAG.
- **Equipos de desarrollo:** responsables de implementar controles en el ciclo de vida del sistema.
- **Oficiales de cumplimiento:** encargados de verificar la adherencia a normativa vigente.
- **Dirección:** tomadores de decisiones que requieren una visión ejecutiva del nivel de riesgo.

1.4 Referencias normativas

El marco LLM-Sec se ancla a las siguientes referencias:

Referencias principales

OWASP	LLM Top 10:2025
ISO/IEC 33001	Evaluación de capacidad de procesos
ISO/IEC 27002:2022	Controles de seguridad de la información
NIST AI RMF	Marco de gestión de riesgos de IA
MITRE ATLAS	Tácticas adversariales para sistemas de IA
Ley 21.663	Marco de Ciberseguridad (Chile)
Ley 21.719	Protección de Datos Personales (Chile)
Boletín 16821-19	Proyecto de Ley de Inteligencia Artificial (Chile)

1.5 Convenciones del documento

A lo largo de este documento se utilizan las siguientes convenciones visuales:

- Los controles se identifican con `C01` – `C62`.
- Los niveles de madurez se representan con etiquetas: N0 N1 N2 N3 N4 N5.
- Los tipos funcionales se distinguen por color: Preventivo Detectivo Correctivo Gobernanza.
- Las fuentes de evidencia se indican como: Configuración Experimental Declarativo.

Capítulo 2

Modelo de madurez

2.1 Identificación de activos del sistema RAG

Toda evaluación de seguridad requiere, como paso previo a la definición de controles, la identificación de los activos sobre los cuales opera el riesgo. Esta práctica está establecida en el NIST CSF 2.0, cuya función *Identify* define la gestión de activos como condición necesaria antes de seleccionar e implementar medidas de protección. En consecuencia, esta sección declara los activos del sistema RAG que el marco LLM-Sec tiene por objeto proteger, delimitando el perímetro de evaluación sobre el cual se articulan los componentes del marco.

A diferencia de un LLM aislado, los sistemas RAG exponen una superficie de ataque distribuida en múltiples componentes encadenados, cada uno de los cuales constituye un activo susceptible de ser comprometido de forma independiente. La Tabla 2.1 presenta los cinco activos identificados, su descripción funcional dentro del flujo RAG y el riesgo principal asociado a cada uno.

Cuadro 2.1: Activos del sistema RAG y riesgos asociados.

ID	Activo	Riesgo principal	Referencia
A1	LLM	Manipulación del comportamiento del modelo mediante inyección de instrucciones maliciosas en lenguaje natural.	LLM01:2025
A2	Base de datos vectorial	Recuperación no autorizada de fragmentos indexados e intoxicación del corpus mediante documentos maliciosos.	LLM08:2025
A3	Corpus de conocimiento	Exposición de información sensible contenida en los documentos indexados mediante consultas diseñadas para exfiltración.	LLM02:2025
A4	Canales de entrada y salida	Transporte de instrucciones maliciosas en la entrada y filtración de información del corpus o del prompt del sistema en la salida.	LLM01, LLM07
A5	Mecanismos de acceso y sesión	Acceso no autorizado a información sensible por ausencia de control de identidad o segregación de permisos.	NIST AI RMF

Cada activo ocupa una posición específica dentro del flujo de inferencia RAG, lo que determina qué vectores de amenaza le son aplicables y, en consecuencia, qué subdimensión del modelo de madurez lo cubre:

Mapeo activo → subdimensión

Activo	Etapa del flujo	Subdimensión	Vectores
A1 (LLM)	Inferencia	D1, D3	LLM01
A2 (Base vectorial)	Recuperación	D2	LLM08
A3 (Corpus)	Recuperación	D2	LLM02
A4 (Canales E/S)	Entrada y salida	D1, D3	LLM01, LLM07
A5 (Acceso y sesión)	Transversal	D4, D5	Transversal

Este mapeo justifica la existencia de exactamente cinco subdimensiones y no un número arbitrario: cada subdimensión protege un subconjunto distinto del flujo RAG, y el modelo de madurez evalúa cada uno de forma independiente antes de agregar un nivel global mediante la regla de piso mínimo (sección 2.6).

La identificación de activos no constituye un componente del marco sino una condición previa a su aplicación. LLM-Sec es un instrumento de evaluación de postura que recibe como entrada un sistema cuyo perímetro ya ha sido delimitado y produce como salida un nivel de madurez verificado. Esta separación es coherente con el diseño agnóstico al dominio: al no fijar el perímetro de activos dentro del marco, este puede aplicarse a cualquier sistema RAG con independencia de su dominio de despliegue.

2.2 Valoración de riesgo por activo

Una vez identificados los activos, el paso siguiente consiste en valorar el riesgo asociado a cada uno. El marco LLM-Sec adopta la definición de riesgo de la Ley 21.663, que lo formula en términos de **probabilidad de ocurrencia** de un incidente y el **impacto de sus consecuencias**. Esta formulación exige que la valoración no sea cualitativa sino cuantificable, lo que justifica el uso de una matriz de riesgo como instrumento de priorización.

2.2.1 Escala de valoración

La valoración emplea dos ejes, cada uno con tres niveles:

Escalas de probabilidad e impacto

Probabilidad de explotación

	Nivel	Criterio
3	Alta	Explotable con herramientas automatizadas de acceso público.
2	Media	Requiere conocimiento técnico específico del sistema.
1	Baja	Requiere acceso privilegiado o condiciones poco frecuentes.

Impacto de compromiso

	Nivel	Criterio
3	Alto	Exfiltración de datos sensibles o pérdida de control del modelo.
2	Medio	Degradación del servicio o exposición parcial de información.
1	Bajo	Impacto operacional contenido, sin exposición de datos.

2.2.2 Matriz de riesgo

La Tabla 2.2 presenta la valoración de riesgo para cada activo identificado en la sección anterior. El nivel de riesgo se obtiene como el producto de probabilidad e impacto, clasificado en tres categorías: **Alto** (≥ 6), **Medio** ($3{-}4$) y **Bajo** (≤ 2).

Cuadro 2.2: Matriz de valoración de riesgo por activo del sistema RAG.

ID	Activo	Probabilidad	Impacto	Riesgo	Clasificación
A4	Canales de E/S	3 (Alta)	3 (Alto)	9	Alto
A1	LLM	3 (Alta)	3 (Alto)	9	Alto
A3	Corpus	3 (Alta)	3 (Alto)	9	Alto
A2	Base vectorial	2 (Media)	3 (Alto)	6	Alto
A5	Acceso y sesión	1 (Baja)	3 (Alto)	3	Medio

2.2.3 Interpretación y priorización

La valoración revela tres hallazgos que condicionan el diseño del modelo de madurez y la distribución de controles:

1. **Los canales de entrada/salida, el LLM y el corpus concentran el riesgo más alto.** Esto se debe a que los vectores LLM01, LLM02 y LLM07 son explotables con herramientas automatizadas de acceso público (como Garak), sin requerir acceso privilegiado al sistema. Esta condición explica que las subdimensiones D1 (Protección de entrada), D2 (Control de contexto RAG) y D3 (Gestión de salida) concentren el mayor volumen de controles en la taxonomía: 17, 18 y 10 respectivamente, frente a 9 de D4 y 15 de D5.

2. **La base vectorial presenta riesgo alto con probabilidad media.** A diferencia de los canales de E/S, la explotación de LLM08 requiere conocimiento específico de la infraestructura de recuperación (tipo de base vectorial, estrategia de indexación, configuración de similitud). No obstante, el impacto de su compromiso es alto porque afecta la integridad de todo el corpus recuperable. Esto justifica que D2 sea la subdimensión con mayor densidad de controles (18), cubriendo tanto los riesgos de alta probabilidad del corpus (LLM02) como los de probabilidad media de la infraestructura vectorial (LLM08).

3. **Los mecanismos de acceso y sesión presentan riesgo medio.** Su probabilidad de explotación es baja en el contexto de un sistema RAG desplegado en red controlada, pero el impacto de su compromiso sigue siendo alto. Esto justifica que el control de acceso (C22) se clasifique como declarativo: su implementación es imprescindible en producción, pero su verificación experimental queda fuera del alcance de un laboratorio controlado en TRL 4.

La valoración presentada corresponde a un sistema RAG genérico. Cada organización debe recalcular la probabilidad y el impacto según su contexto de despliegue específico, utilizando las escalas definidas. El perfil organizacional (P1, P2 o P3) orienta la interpretación del nivel de riesgo aceptable, pero no reemplaza esta valoración.

2.2.4 Trazabilidad hacia las subdimensiones

La siguiente tabla sintetiza cómo la valoración de riesgo justifica la estructura del modelo de madurez:

Riesgo → subdimensión → densidad de controles

Activo	Riesgo	Subdimensión	Controles	Prioridad
A4 (Canales E/S)	Alto (9)	D1, D3	17 + 10	Máxima
A1 (LLM)	Alto (9)	D1, D3	17 + 10	Máxima
A3 (Corpus)	Alto (9)	D2	18	Máxima
A2 (Base vectorial)	Alto (6)	D2	18	Alta
A5 (Acceso y sesión)	Medio (3)	D4, D5	9 + 15	Media

Esta trazabilidad garantiza que la distribución de controles del marco no es arbitraria, sino proporcional al riesgo valorado de cada activo. Las subdimensiones con mayor densidad de controles (D1, D2, D3) corresponden a los activos con mayor nivel de riesgo, mientras que D4 y D5, asociadas a activos de riesgo medio, priorizan la observación y la gobernanza sobre la intervención directa.

2.3 Estructura del modelo

A partir de los activos identificados y su valoración de riesgo (secciones 2.1 y 2.2), el modelo de madurez LLM-Sec define seis niveles (N0 a N5) que representan una escala ordinal de la postura de ciberseguridad de un sistema RAG. La progresión es acumulativa: alcanzar un nivel N_k requiere satisfacer todos los criterios de los niveles N_0 a N_{k-1}. Las distancias entre niveles no son uniformes; cada nivel refleja un salto cualitativo en la solidez de los procesos, no un incremento lineal. Esta propiedad tiene una consecuencia estadística directa: el coeficiente apropiado para medir la correlación entre el nivel asignado y la resistencia experimental observada es Spearman, dado que no se asumen distancias iguales entre categorías.

El modelo evalúa cinco subdimensiones derivadas de los ítems del OWASP LLM Top 10:2025 pertinentes al flujo RAG, cuya trazabilidad hacia los activos del sistema se estableció en la sección 2.1. Dado que no existe un modelo de madurez estandarizado para arquitecturas RAG en la literatura actual, esta derivación constituye una contribución original del marco.

2.4 Niveles de madurez

N0: Inexistente

Sin consciencia de seguridad. No existen controles, políticas ni identificación de riesgos asociados al sistema RAG. Estado previo al despliegue del sistema; no genera artefactos de evaluación.

N1: Inicial

Los riesgos son reconocidos pero no se han implementado controles para abordarlos. El sistema opera sin mecanismos de protección activos, asumiendo implícitamente los riesgos existentes. Corresponde a un sistema RAG desplegado sin capa defensiva.

N2: Reactivo

Controles básicos implementados de forma parcial o no sistemática. Respuesta ante incidentes conocidos, no preventiva. Se evidencia mediante la activación de una capa defensiva con configuración por defecto; la tasa de filtrado de ataques es positiva pero variable entre categorías.

N3: Definido

Controles formalmente definidos, documentados y aplicados de forma consistente. Umbrales de detección establecidos antes de la operación. Los logs de la capa defensiva son trazables por escáner y categoría de amenaza.

N4: Gestionado

Seguridad gestionada cuantitativamente. Métricas de desempeño definidas y controles ajustados según resultados medidos. El nivel de correlación entre la puntuación del checklist y la resistencia experimental es estadísticamente significativo.

N5: Optimizado

Mejora continua. Controles actualizados proactivamente ante nuevas amenazas documentadas. Marco revisado periódicamente e integrado al ciclo de gestión de riesgos organizacional. Requiere validación longitudinal y en múltiples dominios.

2.5 Subdimensiones

Subdimensiones del modelo LLM-Sec

ID	Nombre	OWASP	Captura
D1	Protección de entrada	LLM01	Validación y sanitización de prompts
D2	Control de contexto RAG	LLM02, LLM08	Acceso y exposición de la base vectorial
D3	Gestión de salida	LLM01, LLM07	Filtrado y control de respuestas
D4	Monitoreo y trazabilidad	Todos	Logging, alertas y auditoría
D5	Gobernanza organizacional	—	Roles, políticas y cultura de seguridad

2.5.1 D1: Protección de entrada

La subdimensión D1 agrupa los controles orientados a la validación y sanitización de prompts de entrada, constituyendo la primera línea de defensa del flujo RAG. Opera sobre los canales de entrada y el LLM, interceptando la amenaza antes de que alcance la capa de inferencia. Su verificación combina evidencia de configuración (archivos YAML, prompt del sistema) con validación experimental (resultados de auditoría ofensiva).

2.5.2 D2: Control de contexto RAG

La subdimensión D2 abarca los controles que regulan el acceso, la exposición y la integridad de la base de datos vectorial y el corpus de conocimiento. Opera sobre la etapa de recuperación del flujo RAG, donde los fragmentos de contexto son seleccionados y entregados al modelo como parte del prompt aumentado.

2.5.3 D3: Gestión de salida

La subdimensión D3 comprende los controles que filtran y regulan las respuestas generadas por el modelo antes de entregarlas al usuario. Opera sobre el canal de salida del flujo RAG, constituyendo la última línea de defensa contra la exfiltración de información sensible y la fuga del prompt del sistema.

2.5.4 D4: Monitoreo y trazabilidad

La subdimensión D4 opera de forma transversal sobre el sistema RAG completo. Su naturaleza es observacional: no interviene sobre el flujo sino que lo registra. Sus entradas son eventos

generados por las tres subdimensiones anteriores y sus salidas son exclusivamente artefactos de auditoría.

D4 no define controles de nivel N1 porque el monitoreo mínimo viable requiere que el sistema disponga de algún mecanismo activo de registro, condición que no se cumple en un sistema sin capa defensiva. Un sistema en esa condición se clasifica como no conforme en esta subdimensión.

2.5.5 D5: Gobernanza organizacional

La subdimensión D5 opera de forma transversal sobre la organización completa, no sobre una etapa técnica específica del flujo RAG. Captura las obligaciones institucionales de gestión de la seguridad: definición de roles y responsabilidades, políticas de uso, cumplimiento normativo y mejora continua del marco. Su verificación es exclusivamente declarativa, dado que requiere métodos cualitativos como auditorías organizacionales o revisión documental, incompatibles con un entorno de laboratorio controlado.

D5 provee insumos normativos e institucionales a las demás subdimensiones, actuando como el proceso de gobernanza que sustenta la operación segura del sistema RAG en su conjunto. Sus entradas son marcos normativos y retroalimentación de D4, y sus salidas son políticas e instrumentos de gobernanza que condicionan la operación del resto del sistema.

2.6 Regla de piso mínimo

El nivel global L del sistema se determina como:

$$L = \text{mín}(d_1, d_2, d_3, d_4, d_5)$$

donde d_i es el nivel verificado de la subdimensión i. La justificación subyacente es que la postura de seguridad de un sistema es tan sólida como su componente más débil. A modo de ejemplo, si D1, D2 y D3 alcanzan nivel 4 pero D4 alcanza nivel 2, el nivel global verificado es 2.

Dado que D5 opera exclusivamente con fuente de evidencia declarativa, su nivel no es verificable mediante experimento de laboratorio. El marco distingue por tanto entre **nivel verificado** (determinado mediante evidencia experimental o de configuración, aplicable a D1–D4) y **nivel declarado** (determinado mediante lista de chequeo sin evidencia técnica directa, aplicable a D5).

En cuanto a la ponderación dentro de cada subdimensión, todos los controles de un mismo nivel tienen peso equivalente. Esta decisión se justifica porque la ausencia de literatura previa comparable impide anclar ponderaciones diferenciales a evidencia empírica; asignar pesos arbitrarios introduciría un sesgo no justificable.

Capítulo 3

Taxonomía de controles

3.1 Estructura de los controles

Cada control se caracteriza por cinco atributos:

1. **Nivel de madurez** (N1 a N5): determina en qué nivel del modelo se requiere su implementación.
2. **Tipo funcional**: preventivo, detectivo, correctivo o gobernanza, según el momento en que actúa respecto al evento de seguridad (ISO/IEC 27002:2022).
3. **Fuente de evidencia**: configuración (archivos YAML, prompt del sistema), experimental (resultados de auditoría ofensiva) o declarativo (verificación por lista de chequeo).
4. **Descripción**: acción específica que el control requiere.
5. **Fuente normativa**: referencia al estándar o legislación que lo origina.

Un control puede satisfacer más de un tipo funcional simultáneamente, consistente con el modelo de atributos de ISO/IEC 27002:2022. Por ejemplo, un escáner de salida que identifica y suprime contenido sensible actúa como control detectivo y correctivo en una misma operación.

Todos los controles de un mismo nivel tienen peso equivalente dentro de su subdimensión.

El conjunto completo comprende 62 controles distribuidos en cinco subdimensiones y cinco niveles de madurez. Las secciones siguientes presentan los controles organizados por subdimensión.

3.2 D1: Protección de entrada

La subdimensión D1 agrupa 17 controles distribuidos en cinco niveles de madurez: 8 en N1, 3 en N2, 2 en N3, 2 en N4 y 2 en N5. El predominio de controles preventivos refleja la naturaleza de esta subdimensión: interceptar la amenaza antes de que alcance la capa de inferencia.

C01 N1

Limitar longitud máxima del prompt de entrada.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025

C02 N1

Sanitizar el prompt de entrada eliminando caracteres y patrones de control.

Tipo: Preventivo **Evidencia:** Experimental **Fuente:** LLM01:2025

C06 N1

Segregar e identificar contenido externo en el prompt mediante delimitadores explícitos.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025, LLM02:2025

C13 N1

Limitar el volumen total de contexto inyectado al LLM por sesión.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025

C15 N1

Restringir el rol, capacidades y limitaciones del modelo en el prompt del sistema.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025

C16 N1

Interponer un proxy de seguridad externo e independiente del LLM.

Tipo: Preventivo **Evidencia:** Configuración **Fuente:** LLM01:2025

Pendiente

Trasladar los 17 controles de D1 desde la Tabla 3.28 de la tesis utilizando el comando `\control`.

3.3 D2: Control de contexto RAG

La subdimensión D2 agrupa 18 controles orientados a regular el acceso, la exposición y la integridad de la base de datos vectorial y el corpus de conocimiento. La distribución por nivel refleja una progresión desde controles básicos de particionamiento y sanitización (N1) hasta mecanismos de auditoría avanzada y mejora continua (N5).

Pendiente

Trasladar los 18 controles de D2 desde la Tabla 3.30 de la tesis.

3.4 D3: Gestión de salida

La subdimensión D3 comprende 10 controles que filtran y regulan las respuestas generadas por el modelo antes de entregarlas al usuario, constituyendo la última línea de defensa contra la exfiltración de información sensible y la fuga del prompt del sistema.

Pendiente

Trasladar los 10 controles de D3 desde la Tabla 3.31 de la tesis.

3.5 D4: Monitoreo y trazabilidad

La subdimensión D4 agrupa 9 controles de naturaleza observacional, distribuidos a partir de N2. D4 no define controles de nivel N1 porque el monitoreo mínimo viable requiere que el sistema disponga de algún mecanismo activo de registro, condición que no se cumple en un sistema sin capa defensiva.

Pendiente

Trasladar los 9 controles de D4 desde la Tabla 3.32 de la tesis.

3.6 D5: Gobernanza organizacional

La subdimensión D5 agrupa 15 controles de tipo exclusivamente Gobernanza con fuente de evidencia Declarativa. Estos controles capturan las obligaciones institucionales derivadas de la Ley 21.663, la Ley 21.719, el NIST AI RMF y el Proyecto de Ley de IA.

Pendiente

Trasladar los 15 controles de D5 desde la Tabla 3.34 de la tesis.

3.7 Distribución de controles

La siguiente tabla resume la distribución de los 62 controles por subdimensión y nivel de madurez.

Distribución de controles: subdimensión × nivel

Subdim.	N1	N2	N3	N4	N5	Total
D1	8	3	2	2	2	17
D2	6	5	3	2	2	18
D3	3	3	2	1	1	10
D4	0	3	3	1	2	9
D5	4	2	4	2	3	15
Total	21	16	14	8	10	**62**

Nota

Verificar que los totales de esta tabla coincidan con las tablas de la tesis. Algunos controles pueden aparecer en más de una subdimensión dado que su función de protección es transversal.

Capítulo 4

Perfiles organizacionales

Los perfiles organizacionales orientan la interpretación del nivel de madurez asignado según el tipo de organización. No modifican los criterios de asignación ni la definición de los niveles; únicamente establecen el nivel mínimo recomendado y el nivel objetivo según las obligaciones regulatorias aplicables.

Resumen de perfiles

Perfil	Tipo	Nivel mínimo	Nivel objetivo	Descripción
P1	PYME	N1	N3	Organizaciones pequeñas y medianas
P2	Mediana/Grande	N2	N4	Organizaciones con infraestructura formal
P3	Crítica regulada	N3	N5	Infraestructura crítica, sector regulado

4.1 P1: PYME

El perfil P1 está diseñado para pequeñas y medianas empresas que despliegan sistemas RAG con recursos limitados de ciberseguridad. El nivel mínimo recomendado es N1 y el nivel objetivo es N3.

4.1.1 Trayectoria recomendada

1. **N1 (Inicial):** Implementar los controles preventivos básicos de D1 y D2. Desplegar un prompt del sistema con instrucciones de seguridad. Activar la capa defensiva con configuración por defecto.
2. **N2 (Reactivo):** Configurar umbrales de detección y habilitar logging básico (D4). Establecer política de uso aceptable (D5).
3. **N3 (Definido):** Documentar formalmente los controles implementados. Calibrar umbrales basándose en resultados de auditoría. Establecer trazabilidad completa por escáner.

4.1.2 Controles prioritarios

Pendiente

Identificar y listar los controles prioritarios para P1 considerando costo de implementación e impacto en TFA.

4.2 P2: Mediana/Grande

El perfil P2 aplica a organizaciones medianas y grandes con infraestructura formal de seguridad de la información. El nivel mínimo recomendado es N2 y el nivel objetivo es N4.

4.2.1 Trayectoria recomendada

1. **N2 (Reactivo):** Todos los controles de N1 implementados. Configuración activa de la capa defensiva con umbrales ajustados. Monitoreo básico operativo.
2. **N3 (Definido):** Controles documentados y aplicados consistentemente. Auditoría ofensiva periódica. Matriz RACI asignada.
3. **N4 (Gestionado):** Métricas de desempeño definidas (TFA, LAS). Controles ajustados según resultados cuantitativos. Monitoreo de patrones de consulta anómalos.

4.2.2 Controles prioritarios

Pendiente

Identificar y listar los controles prioritarios para P2.

4.3 P3: Crítica regulada

El perfil P3 aplica a organizaciones que operan infraestructura crítica o pertenecen a sectores regulados, donde las obligaciones de la Ley 21.663 y la Ley 21.719 imponen requisitos formales de ciberseguridad y protección de datos. El nivel mínimo recomendado es N3 y el nivel objetivo es N5.

4.3.1 Trayectoria recomendada

1. **N3 (Definido):** Todos los controles de N1–N2 implementados y documentados. Trazabilidad completa. Evaluación de riesgos formal.
2. **N4 (Gestionado):** Gestión cuantitativa de la seguridad. Proceso formal de gestión de riesgos de IA con clasificación por criticidad. Reportes periódicos a dirección.
3. **N5 (Optimizado):** Mejora continua integrada. Marco revisado ante cambios normativos o nuevas amenazas. Lecciones aprendidas incorporadas al ciclo de gobernanza.

4.3.2 Obligaciones regulatorias aplicables

Las organizaciones bajo el perfil P3 deben considerar especialmente:

- **Ley 21.663:** obligaciones de notificación de incidentes, designación de responsable de seguridad, inventario de activos de información.
- **Ley 21.719:** obligaciones del responsable de tratamiento, inventario de datos personales procesados por el sistema RAG.
- **Proyecto de Ley de IA:** clasificación del sistema según nivel de criticidad, métricas de desempeño de gobernanza.

4.3.3 Controles prioritarios

Pendiente

Identificar y listar los controles prioritarios para P3 con énfasis en cumplimiento normativo.

Capítulo 5

Guía de evaluación

5.1 Flujo de evaluación

El proceso de evaluación del marco LLM-Sec sigue seis pasos secuenciales:

1. **Selección del perfil organizacional:** identificar el perfil (P1, P2 o P3) que corresponde a la organización según su tipo y obligaciones regulatorias.
2. **Evaluación de controles:** verificar cada control de las subdimensiones D1 a D5 utilizando la fuente de evidencia correspondiente (configuración, experimental o declarativa).
3. **Asignación de nivel por subdimensión:** el nivel de cada subdimensión es el mayor nivel cuyos controles están completamente implementados, respetando la progresión acumulativa.
4. **Cálculo del nivel global:** aplicar la regla de piso mínimo: $L = \text{mín}(d_1, d_2, d_3, d_4, d_5)$.
5. **Análisis de brechas:** identificar la distancia entre el nivel verificado y el nivel objetivo del perfil seleccionado.
6. **Plan de remediación:** priorizar la implementación de controles faltantes según el nivel objetivo, enfocándose primero en la subdimensión que actúa como piso.

5.2 Nivel verificado y nivel declarado

El marco distingue dos tipos de nivel asignado según la fuente de evidencia utilizada:

Nivel verificado: determinado mediante evidencia experimental (resultados de auditoría ofensiva, logs de la capa defensiva) o de configuración (archivos YAML, prompt del sistema). Aplica a las subdimensiones D1, D2, D3 y D4.
Nivel declarado: determinado mediante lista de chequeo sin evidencia técnica directa, basado en auditoría organizacional o revisión documental. Aplica a la subdimensión D5.

Al reportar el resultado de una evaluación, el evaluador debe indicar explícitamente qué subdimensiones fueron verificadas y cuáles fueron declaradas. El nivel global debe acompañarse de esta distinción para evitar interpretaciones que asuman verificación completa.

5.3 Criterios de verificación por fuente de evidencia

5.3.1 Configuración

El control se verifica inspeccionando la declaración explícita en los archivos de configuración del sistema. Ejemplos: presencia de umbrales en el archivo YAML de la capa defensiva, instrucciones de seguridad en el prompt del sistema, particionamiento de la base vectorial.

5.3.2 Experimental

El control se verifica mediante la ejecución de pruebas de auditoría ofensiva contra el sistema bajo evaluación. El resultado se expresa como una métrica cuantificable (tasa de filtrado, latencia, cobertura). La herramienta de auditoría debe ejecutar probes alineados a las categorías OWASP cubiertas por el control.

5.3.3 Declarativo

El control se verifica mediante revisión documental o entrevista. El evaluador solicita evidencia de la existencia de la política, procedimiento o asignación de roles descrita por el control.

5.4 Matriz RACI

El marco define roles genéricos que cada organización debe mapear a personas o cargos concretos. La matriz RACI establece las responsabilidades para las actividades principales del ciclo de evaluación.

Pendiente

Trasladar la matriz RACI desde la tesis, adaptándola al formato del documento del marco.

5.5 Ciclo de mejora

Ante brechas identificadas entre el nivel verificado y el nivel objetivo, el evaluador debe:

1. Identificar la subdimensión que actúa como piso mínimo.
2. Priorizar los controles faltantes de esa subdimensión en el nivel inmediatamente superior.
3. Implementar los controles priorizados.
4. Re-ejecutar la evaluación para verificar el tránsito de nivel.

Este ciclo es iterativo y se repite hasta alcanzar el nivel objetivo del perfil organizacional o hasta que los riesgos residuales sean formalmente aceptados y documentados por la dirección.

Apéndice A

Resumen de controles por nivel

Apéndice B

Mapeo normativo